

DFIR CHEAT SHEET: Procedimientos de Primer Interviniente y Triage Inicial

Este documento establece las directrices técnicas críticas para las primeras acciones ante un incidente de ciberseguridad o secuestro de dispositivos. El objetivo es maximizar la recolección de evidencia volátil y evitar la contaminación de la escena digital.

1. ERRORES CRÍTICOS (LO QUE NO SE DEBE HACER)

- **NO apagar el equipo ("Pull the plug"):** Apagar el sistema destruye irremediablemente la memoria RAM, eliminando claves de cifrado en memoria (Ransomware), malware residente en memoria (Fileless), procesos activos y conexiones de red de los atacantes.
- **NO interactuar innecesariamente con el sistema comprometido:** Cada clic, apertura de explorador o ejecución de comandos altera las marcas de tiempo (MAC: Modified, Accessed, Created) en el sistema de archivos (MFT en NTFS, Inodes en ext4).
- **NO conectar unidades externas no esterilizadas:** Todo pendrive de recolección (Live USB) debe estar preparado forensemente, sin autorun y operando con herramientas estáticas (binarios compilados que no dependan de librerías del sistema host).
- **NO usar las herramientas nativas del sistema infectado:** Si el equipo está comprometido (ej. Rootkit), binarios como netstat, ps o ls pueden estar modificados para ocultar al atacante. Use herramientas precompiladas desde su unidad de respuesta.

2. ORDEN DE VOLATILIDAD ESTÁNDAR (IETF RFC 3227)

Al momento de adquirir, proceda estrictamente desde lo más volátil a lo menos volátil:

1. **Registros del CPU y Caché:** (Generalmente inaccesible sin hardware especializado).
2. **Tablas de Enrutamiento, Caché ARP, Tablas de Procesos, Estadísticas del Kernel.**
3. **Memoria Principal (RAM):** Volcado completo (Memory Dump).
4. **Estado de Red Temporal:** Conexiones TCP/UDP activas.
5. **Almacenamiento Temporal / Memoria Virtual:** Archivos de paginación (pagefile.sys, swap).
6. **Medios Físicos (Discos Duros):** Adquisición bit a bit de HDD/SSD.
7. **Datos Remotos / Backups.**

3. PROCEDIMIENTO DE AISLAMIENTO DE RED

La decisión de aislar o mantener conectado depende del objetivo (contención vs. inteligencia). Si el objetivo es preservar la evidencia:

- **Equipos de Escritorio / Servidores:** Desconectar el cable Ethernet físico y/o deshabilitar interfaces inalámbricas lógicamente mediante comandos rápidos de bajo nivel (ej. `ifconfig eth0 down` / `ip link set eth0 down` desde un entorno controlado, aunque documentando la alteración).
- **Dispositivos Móviles:** Aislar inmediatamente en bolsas de Faraday (Faraday bags) para bloquear señales RF (Celular, Wi-Fi, Bluetooth) y prevenir comandos de borrado remoto (Wipe) de Mobile Device Management (MDM) o atacantes. Activar Modo Avión no siempre interrumpe el GPS o chips baseband.

4. PRE-FLIGHT CHECKS: ENTORNO CENTRUX

Antes de montar cualquier evidencia lógica o física adquirida en la estación de análisis (Centrux):

1. **Verificación de Identidad (Hashes):** Calcule el hash (SHA-256) de la imagen adquirida y compárelo con el documentado en el acta de secuestro original antes de interactuar.
 - o `sha256sum imagen_evidencia.dd`
2. **Bloqueo de Escritura (Software Write-Blocking):** Garantice el montaje en modo de Solo Lectura Estricto (Read-Only) para evitar contaminación accidental del sistema de archivos.
 - o Ejemplo de comando de montaje seguro: `mount -o ro,loop,noexec imagen_evidencia.dd /mnt/evidencia`
3. **Aislamiento del Entorno Analítico:** Verifique que la máquina virtual o estación física de Centrux tenga deshabilitados los adaptadores de red o configurados en "Host-Only" antes de procesar artefactos potencialmente maliciosos.

5. DOCUMENTACIÓN MÍNIMA REQUERIDA (IN-SITU)

Antes de alterar el estado del sistema, documente fotográficamente y por escrito:

- Estado de la pantalla (bloqueada, ventanas abiertas, mensajes de ransomware).
- Conexiones físicas al equipo (cables de red, USB conectados, periféricos).
- Fecha y hora mostradas por el reloj del sistema operativo y su desviación (skew) respecto a un reloj atómico estándar (NTP).
- Datos del hardware: Marca, modelo, número de serie (S/N) y Service Tag.